POLARIS

Firewall menahan yang terlihat. POLARIS menangkap yang menyembunyikan diri.

Peringatan dini berbasis tipuan untuk jaringan IT dan OT. Setiap interaksi dengan umpan adalah bukti intent, bukan tebakan statistik.

deteksi deterministik | satu binary Go | on-prem dan air-gap | MITRE ATT&CK plus ATT&CK for ICS

Ajang

Kartika Cyber Hackathon 2026

Kategori

02 Defensive Shield, penangkalan

Penyelenggara

PUSSIBERAD bersama Codepolitan

Status purwarupa

Berjalan dan sudah diuji dengan alat penyerang sungguhan

Tiga masalah struktural, bukan kekurangan alat

Ketiganya sudah lama diketahui, dan ketiganya belum selesai.

01 **Alert fatigue**

IDS dan SIEM berbasis anomali menghasilkan ratusan sampai ribuan alert per hari, mayoritas keliru. Sinyal penting tenggelam, dan analis berhenti mempercayai sistemnya.

02 **Penyerang yang sudah masuk jadi tak terlihat**

Perangkat perimeter tidak melihat apa yang terjadi setelah initial access. Pemindaian internal, lateral movement, dan pencarian kredensial berjalan di jalur yang dianggap tepercaya.

03 **Konteks jaringan militer**

Banyak jaringan TNI AD terisolasi atau air-gap, dan mencampur IT dengan OT seperti SCADA, PLC, serta HMI. Solusi yang bergantung pada cloud tidak bisa dipasang di sana.

Kesalahan terbesarnya: mencoba menebak arti kata normal

Deteksi klasik menghabiskan tenaga untuk memisahkan lalu lintas normal dari yang mencurigakan. Pemisahan itu sifatnya probabilistik, dan di situlah false positive lahir.

Yang POLARIS lakukan sebagai gantinya: menanam umpan yang secara desain mustahil disentuh pengguna sah. Pertanyaannya berubah dari "apakah ini mencurigakan" menjadi "mengapa ada yang menyentuh ini", dan jawaban untuk pertanyaan kedua selalu punya bukti.

Port palsu tanpa layanan

32 port umpan menerima sambungan. Tidak ada pengguna sah yang punya alasan menyentuhnya, jadi tidak ada sinyal jinak yang perlu dipisahkan.

Berkas kredensial tak dipakai

11 berkas umpan termasuk `.env` dan kredensial cloud. Tidak ada proses yang seharusnya membacanya, sehingga pembacaan berarti bukti.

Perangkat OT tiruan

Decoy Modbus dan HMI meniru perangkat ICS yang tidak ada di topologi nyata. Probe protokol OT ke sana tidak punya penjelasan wajar.

Umpan tidak pernah tersentuh operasi normal, jadi tidak ada ambang batas untuk dituning dan tidak ada sinyal jinak yang perlu dipisahkan pada saat keputusan diambil.

Dua pendekatan, satu baris dibaca sebagai pasangan

Setiap baris membandingkan sifat yang sama pada dua pendekatan

IDS atau IPS konvensional	POLARIS
Deteksi probabilistik lewat anomali	Deteksi deterministik lewat umpan
Ribuan alert, banyak yang keliru	Sedikit alert, semuanya dari bukti sentuhan
Perlu tuning ambang batas	Tidak ada ambang batas untuk dituning
Bergantung pada pola serangan yang sudah dikenal	Bergantung pada satu fakta: tidak ada pengguna sah di umpan
Butuh cloud atau threat intelligence	Sepenuhnya on-prem, jalan di jaringan tertutup
Hanya IT	IT dan OT atau ICS

nol ambang batas untuk dituning

setiap alert berasal dari bukti sentuhan

perbandingan sifat, bukan perbandingan merek

Purwarupa yang berjalan, bukan mockup

32	11	2	12	0
listener port umpan	berkas honeytoken	decoy OT/ICS (Modbus, HMI)	teknik ATT&CK	dependensi eksternal di agen

Umpan pada lapisan jaringan

`:21 ftp` `:23 telnet` `:25 smtp` `:80 http` `:445 smb` `:502 modbus`
`:2222 ssh` `:2375 docker` `:3306 mysql` `:3389 rdp` `:6379 redis`
`:8080 hmi` `:9200 elasticsearch` `:27017 mongodb`

Daftar lengkapnya 32 port, termasuk NetBIOS, Oracle, MSSQL, memcached, VNC, dan WebLogic.

Umpan pada lapisan yang lebih dalam

Berkas honeytoken. `.env`, `credentials.txt`, `id_rsa_backup`, `.aws/credentials`, `.git/config`, `vault-token.txt`, dan lainnya. Dipantau dengan inotify, jadi membaca isinya sudah memicu event.

Kredensial canary. Kredensial palsu berisi URL beacon. Siapa pun yang memakainya akan menghubungi URL itu, dan itu bukti langsung bahwa kredensial sudah dipanen lalu dipakai.

Decoy OT atau ICS. Modbus TCP pada :502, HMI pada :8080, plus banner perangkat dan form login palsu.

Tiga komponen, satu binary agen, nol infrastruktur baru

node satuan

Agen Go

Menanam umpan dan membuka listener
Memantau berkas dengan inotify
Menangkap payload dan permintaan HTTP
Menyimpan ke spool lokal bila collector mati
Hanya pustaka standar Go

tangkap
kirim

satu collector pusat

Collector dan engine

Python dan FastAPI
Menyaring aktivitas jinak yang sudah dikenal
Menggabungkan event menjadi incident
Menilai severity dan memetakan ATT&CK
SQLite tertanam, tanpa server basis data

petakan
laporkan

ruang operator

Dashboard dan alert

Halaman statis, tanpa build step
Feed langsung lewat WebSocket
Detail incident, timeline, evidence
Telegram dan webhook

Satu collector cukup untuk satu satuan. Menambah node hanya menambah agen, tanpa mengubah arsitektur.

Empat langkah, semuanya bisa diperiksa ulang

Penyaringan aktivitas jinak

Health check internal dan pola probe yang sudah dikenal disisihkan ke jalur terpisah. Event-nya tetap tersimpan dan tetap bisa dilihat, tetapi tidak menjadi incident. Pada demo, 2 event masuk ke jalur ini dan angkanya muncul di dashboard sebagai baris Disaring.

Atribusi tool

Ciri pola koneksi dipakai untuk menebak alat penyerang. Pada demo, nmap dikenali dengan keyakinan 86 persen, dengan masscan dibedakan lewat laju koneksi.

Korelasi dan penilaian

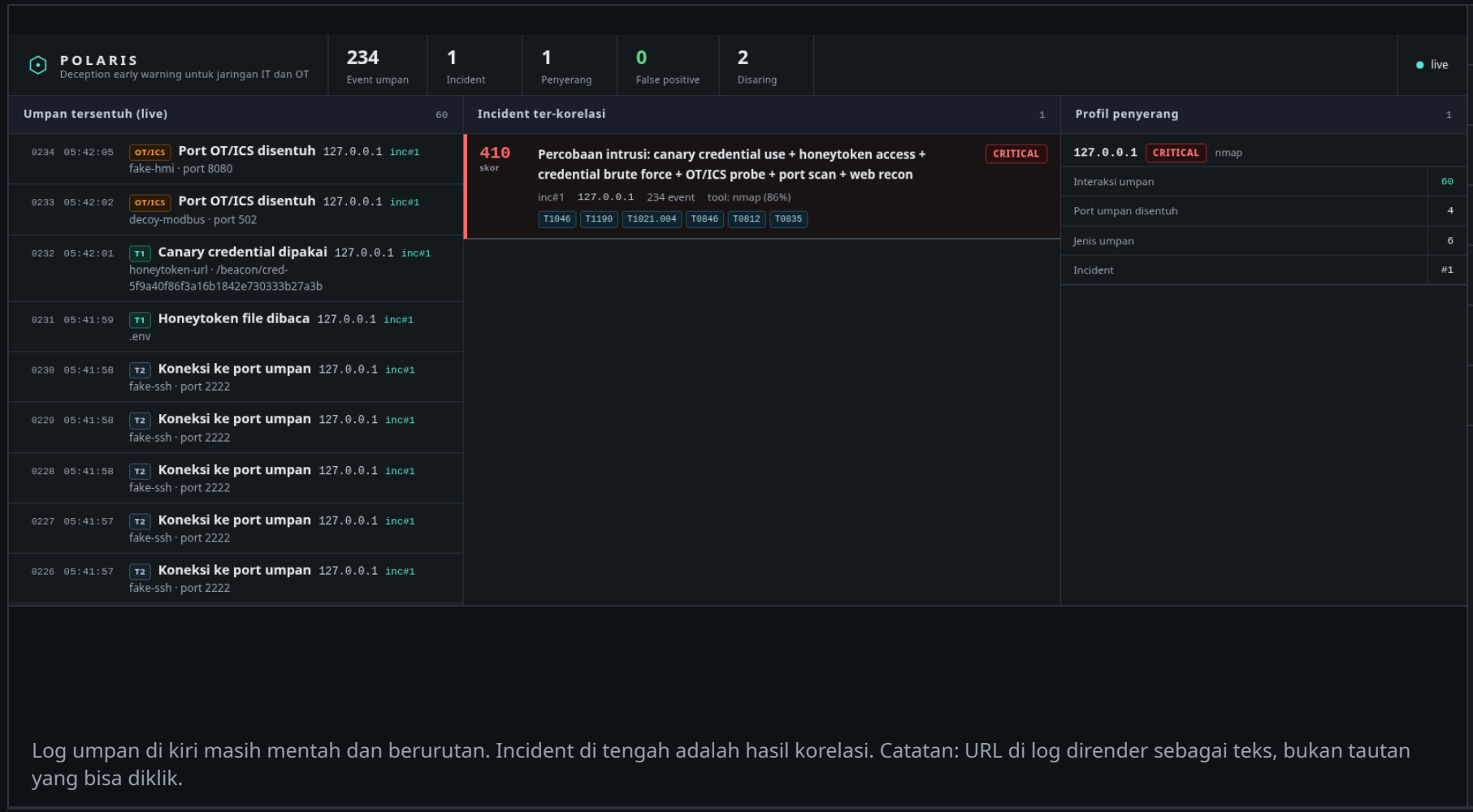
Event dari satu sumber digabung menjadi satu incident. Skornya dibentuk dari jenis bukti yang terkumpul: kredensial umpan yang terbukti dipakai, akses berkas honeytoken, credential brute force, probe protokol OT, pemindaian port, dan pemeriksaan web.

Pemetaan ATT&CK dan ringkasan

Setiap incident dipetakan ke teknik ATT&CK, termasuk ATT&CK for ICS, lalu diberi ringkasan yang disusun dari data yang tercatat. Ringkasan saat ini deterministik: templat yang diisi fakta, bukan model bahasa.

234	2	1	86%	0
event mentah masuk	event disaring ke jalur terpisah	incident hasil korelasi	keyakinan atribusi nmap	false positive

234 event mentah menjadi satu incident, dari serangan sungguhan



Log umpan di kiri masih mentah dan berurutan. Incident di tengah adalah hasil korelasi. Catatan: URL di log dirender sebagai teks, bukan tautan yang bisa diklik.

Severity	CRITICAL
Skor	410
Event ter-korelasi	234
Tool terduga	nmap 86%
Jenis umpan tersentuh	10
Teknik ATT&CK	12
False positive	0

Ciri pola mengarah ke nmap dengan keyakinan 86 persen. Probing protokol OT atau ICS terdeteksi pada decoy Modbus dan HMI, dan kredensial canary terbukti dipakai.

nol false positive

dinilai deterministik dari bukti sentuhan

Bukan daftar label, tetapi peta yang dibaca per taktik

12 teknik dari satu insiden

Reconnaissance	T1595
Discovery	T1046, T1083
Initial Access	T1190
Lateral Movement	T1021.004
Credential Access	T1110, T1552
Defense Evasion	T1078
ICS Discovery	T0846
ICS Credential Access	T0812
ICS Impact	T0835, T0836

Mencakup rantai lengkap, dari pengintaian sampai upaya memanipulasi proses industri.

Dasar atribusi tool, bukan tebakan nama

Tool	Ciri yang menjadi dasar
nmap	Koneksi bertahap per port, jeda tidak rata, ada pemeriksaan versi layanan
masscan	Laju sangat tinggi, banyak port pada satu rentang waktu
hydra	Percobaan login berulang pada port yang sama
curl atau wget	Satu permintaan HTTP dengan satu user agent tetap

ATT&CK Enterprise | ATT&CK for ICS | evidence disimpan per event

Yang diperlihatkan video demo, dengan alat penyerang sungguhan

Satu berkas skrip menjalankan seluruh urutan ini: `demo/demo.sh`

Langkah	Alat	Yang muncul di POLARIS
0. Bersihkan keadaan	tidak ada	Dashboard kosong, nol alert, satu pesan keadaan kosong
1. Pengintaian layanan	nmap	Koneksi berurutan ke port umpan, T1046
2. Penyapuan cepat	masscan	Lonjakan koneksi dari banyak port, pola berbeda dari nmap
3. Pemeriksaan web	nikto	Akses ke path admin dan path sensitif, T1595
4. Credential spray	hydra	Percobaan login berulang ke decoy SSH, T1110
5. Kredensial canary dipakai	skrip	Beacon masuk lewat URL canary, T1552
6. Berkas honeytoken dibaca	skrip	Event akses berkas, T1083
7. Probe OT atau ICS	Modbus FC03	Decoy Modbus dan HMI tersentuh, T0846 dan T0836
8. Hasil	tidak ada	Satu incident kritis, 234 event, nol false positive

Satu baris untuk memasang agen

Pasang

Satu perintah memasang agen di node satuan.

```
bash installer/install.sh
```

Untuk jaringan tertutup, ada mode pemasangan dari binary lokal yang sudah tersedia.

Jalankan

Collector dan dashboard berjalan di satu host, tanpa server basis data terpisah.

```
bash scripts/dev-up.sh
```

SQLite tertanam. Nol container, nol orkestrasi, nol cloud.

Perluas

Menambah node berarti mengulang langkah pemasangan di host berikutnya.

```
POLARIS_CORE_URL=http://kolektor:8787
```

Arsitektur tidak berubah dari satu node ke banyak node.

Agen berjalan sebagai satu binary Go tanpa dependensi eksternal. Bila collector sedang tidak bisa dihubungi, agen menyimpan event ke spool lokal lalu mengirimnya kembali.

Posisi pada tiap kriteria, dengan bukti yang bisa diperiksa

Bobot	Kriteria	Yang sudah ada di purwarupa
25%	Relevansi dan manfaat	Decoy OT dan ICS, jalan tanpa internet, mengurangi beban analis karena alert hanya lahir dari bukti sentuhan
25%	Inovasi teknis	Paradigma dibalik dari anomali ke tipuan, atribusi tool, korelasi, pemetaan ATT&CK termasuk ICS
25%	Fungsionalitas purwarupa	Berjalan di mesin ini, diuji dengan nmap, masscan, nikto, dan hydra, menghasilkan satu incident kritis
15%	Kelayakan implementasi	Satu binary tanpa dependensi, SQLite tertanam, pemasangan satu baris, nol cloud
10%	Kualitas dokumentasi	Proposal, dokumen teknis, arah desain beserta alasannya, skrip demo, dan tabel pemetaan ATT&CK

25% relevansi | 25% inovasi | 25% fungsionalitas, sudah dibuktikan berjalan | 15% kelayakan | 10% dokumentasi

Yang belum kami kerjakan, ditulis terbuka

Batas purwarupa saat ini

- Demo berjalan di satu host, penyerang dan sensor di mesin yang sama, jadi sumber tercatat sebagai 127.0.0.1
- Pembacaan berkas umpan tidak bisa dipisahkan per proses, karena inotify melaporkan berkas yang dibaca, bukan proses yang membacanya
- Atribusi tool adalah perkiraan dari ciri pola, dan alat buatan sendiri bisa menyamarkan pola itu
- Umpan OT atau ICS bersifat tiruan, yang dideteksi adalah pola probe

Langkah berikutnya, berurutan

- Uji lapangan dengan agen di beberapa host pada segmen terpisah, untuk membuktikan atribusi sumber per node
- Ringkasan berbantuan model bahasa, dengan batas jelas: model meringkas, manusia yang memutuskan
- Perluasan sensor OT ke S7 dan DNP3, lalu pengujian dengan perangkat uji industri sungguhan
- Pindah penyimpanan ke PostgreSQL saat volume event satuan sudah terukur

Setiap angka di slide ini berasal dari satu eksekusi demo pada 25 Oktober 2026. Tidak ada statistik, ulasan, atau logo pihak ketiga yang dipakai.

Deteksi kami bukan tebakan. Interaksi dengan umpan adalah bukti.

Firewall menahan yang terlihat. POLARIS menangkap yang menyembunyikan diri, pada jaringan IT maupun OT, tanpa cloud, dengan satu binary agen dan pemasangan satu baris.

Deterministik

Tidak ada ambang batas untuk dituning. Umpan tidak pernah tersentuh operasi normal.

Bukti, bukan klaim

Setiap alert membawa waktu, sumber, payload, dan sidik jari berkas yang bisa diperiksa.

Siap jaringan tertutup

Nol dependensi cloud. Berjalan di segmen yang tidak terhubung ke internet.